

Lecture 4

Legend

Encrypted Key Exchange (EKE)

EKE combines **password-based authentication** with **public-key encryption** to securely establish a session key without revealing the password.

Basic EKE Protocol

1. $(A \rightarrow B : A, \{e_A\}_W)$
 - (A) (initiator) sends their identity and a temporary public key (e_A) , encrypted with the **password-derived key** (W).
2. $(A \leftarrow B : \{E_{e_A}(K)\}_W)$
 - (B) encrypts the **session key** (K) with (e_A) , then encrypts the result with (W).
3. $(A \rightarrow B : \{T\}_K)$
 - (A) confirms knowledge of (K) by sending a test value (T), encrypted with (K).

Analysis

- Attackers **cannot verify** password guesses for (W) without first decrypting (K), making brute-force attacks harder.

Diffie-Hellman EKE (DH-EKE)

DH-EKE enhances EKE with **Diffie-Hellman (DH) key exchange**, ensuring that each session generates a new, independent key.

Protocol Steps

1. $(A \rightarrow B : A, \{g^a\}_W)$
 - (A) sends their identity and a **Diffie-Hellman exponent** (g^a), encrypted with (W).
2. $(A \leftarrow B : \{g^b\}_W)$
3. (B) responds with their own DH exponent (g^b), also encrypted with (W).
4. **Key Agreement**
5. (A) and (B) compute the **shared session key** ($K = (g^b)^a = (g^a)^b$) after decrypting each other's DH values.

Forward Secrecy

- Since the session key (K) is **computed from fresh Diffie-Hellman values** in every session, even if the password (W) is later compromised, past sessions remain secure.

Legend

Symbol	Meaning
(A, B)	Communicating parties (Alice and Bob)
(W)	Password-derived encryption key
(e_A)	Temporary public key from (A)
$(E_{e_A}(K))$	Encryption of session key (K) using (e_A)
(g^a, g^b)	Diffie-Hellman public values
(K)	Shared session key computed from DH exchange
(T)	Test value to verify (K)

| Let me know if I missed anything here!